

R3v4: Pro-Grade AI Browser DAW

Product Requirements Document (PRD)

Version	v5.0.0 (2026-04-29)
Author	R3 Team
Status	Active — Canonical Source of Truth
Ref	CLAUDE.md · SKILLS.md · WIRE.txt · Mythos-Skills.pdf

Changelog

Version	Date	Description
v5.0.0	2026-04-29	Mythos-grade security triage added as §7.13 (threat model, fast-path triage, 5 lessons, decision table, SECURITY.md template, batch workflow, anti-patterns, WIRE integration). §7.2 CI Enforcement added (gate table, pipeline order, secret injection pattern). §3.1 monorepo tree completed. §9 roadmap owners changed from @r3-maintainer to @r3; all event-based triggers converted to hard ISO dates. §4.2 palette unification trigger hardened to 2026-07-01. Quick-nav guide and audience segmentation added.
v4.5.0	2026-04-29	Single source of truth pass: Appendix B T-object replaced with §4.2 pointer. §7.11–7.13 collapsed into unified Standing Rules block.
v4.4.0	2026-04-28	Triple-check bug pass: Railway verify command, palette disambiguation note, git remote PAT method, --force-with-lease safety, hardcoded DAW.tsx line number qualification, §2/§3.1 rule deduplication.
v4.3.0	2026-04-27	SKILLS.md full integration: env table, palette T-object, Railway ops, JSX hygiene, deferred roadmap items, operational runbooks.

■ How to Read This Document

This PRD serves multiple roles. Use the table below to jump to the sections most relevant to your task rather than reading linearly.

If you are...	Read first	Then
Starting a new feature	§2 Stack Rules + §3 Arch	§4 UI + §5 AI/Realtime
Patching code	§8 Hygiene + §2	§7.1–7.4 Dev Protocols
Deploying to Railway	§7.5 Migration Protocol	§7.4 Config Lock
Triaging a CVE / Dependabot alert	§7.12 Security Triage (NEW)	SECURITY.md
Updating the roadmap	§9 Roadmap	§6 Monetization tiers
Adding a payment feature	§6 Monetization	§2 Stripe guard
Touching theming/palette	§4 UI Contract + §10 Appendix A	§8.1 Style Guards

■ 1. Project Scope & Mission

Mission: Deliver a fully browser-based DAW that sets a new standard for speed, clarity, musical intelligence, and live instrument UI.

- **Hybrid AI-First:** AI as creative collaborator, not just an assist tool.
- **Production-Grade:** Zero drift between type contract, UI, data, and musical intent.
- **Extensible & Modular:** Built for future integrated node-based VJ and multiplayer DAW features.

■ 2. Stack and Unbreakable Architecture Rules

★ = Hard Guard in codebase. No deviations without RFC and maintainer review.

Area	Library / Standard	Version / Pinned	Notes
Language	TypeScript ★	5.9.3	No any except whitelisted
UI Framework	React ★	18.x	Functional components only
State	Zustand ★	4.x	No Redux
Routing	Wouter ★	2.x	No react-router-dom
Styling	TailwindCSS ★	4.2.4	darkMode: "class"
Theme System	CSS Variables via theme.css	★—	Neon/Acid default palette
Package Mgmt	pnpm ★	10.33.x	Monorepo workspace setup
Auth	JWT	—	No session cookies
Payments	Stripe ★	20.4.1	No alt vendor refs
ORM/DB Client	drizzle-orm	0.39.3	See §7.5 migration rules
DB	PostgreSQL ≥14.x (Railway)	—	Split DB, never SQLite
Audio	Web Audio API	—	All analysis in browser
Realtime	ws	8.20.0	Collab, control, VJ sync
Testing	Vitest	1.6.1	≥42 cases, piped to CI
Node	Node.js ★	22.x (LTS)	Critical for all CLI
esbuild	esbuild (pinned)	0.25.12	Never allow 0.27.x resolution

Node Enforcement

```
.nvmrc in project root contains "22". Run: nvm install 22 && nvm use 22
Penguin and Termux both run Node 18.x — pnpm dev will fail with esbuild TransformError on either.
Never run builds on those machines.
```

Multi-Machine Environment

Machine	Alias	Path	Node	Purpose
Kali	r3v	~/Stable	22.x	Canonical dev — all patches authored here
Penguin (Chromebook Linux)	y4	~/R3v4	18.20.4	Migration/transfer only
Termux (Android)	v4	~/r3v4_extracted	18.x	UI testing only (not canonical repo)

Both Penguin and Termux share the v4 alias but are separate machines on separate hardware. Paths disambiguate them (~/R3v4 vs ~/r3v4_extracted).

Workspace Rules

- All development on **Kali only**. Penguin and Termux are for running specific commands only — never for writing or patching code.
- `~/r3v4_extracted` on Termux is a separate extracted archive — NOT the canonical repo. Changes there must be cherry-picked back to Kali.
- All patch scripts must be read-then-write, never blind apply (WIRE.txt protocol).
- Penguin has two git remotes (gitsafe-backup and origin). Always push to origin explicitly — **git push origin main**. Do not delete gitsafe-backup.
- No imports across phantom dirs (see hygiene baseline §8).
- Only one source of truth for Tailwind config, theme tokens, palette.

■ 3. Product & App Architecture

3.1 Monorepo Layout (Complete)

This is the **complete canonical tree**. No phantom directories. Any new directory requires RFC + maintainer sign-off.

```
/
■ ■ ■ client/
■   ■ ■ ■ src/
■     ■ ■ ■ components/      # Shared UI components
■     ■   ■ ■ ■ ui/          # Design-system primitives
■     ■   ■   ■ ■ ■ daw/      # DAW-specific components
■     ■   ■   ■ ■ ■ vj/       # VJ/visual components
■     ■   ■ ■ ■ pages/
■     ■     ■ ■ ■ DAW.tsx     # Main DAW page (inline T-object palette)
■     ■     ■ ■ ■ Instrument.tsx # Instrument page (inline T-object palette)
■     ■     ■ ■ ■ Landing.tsx
■     ■     ■ ■ ■ Pricing.tsx
■     ■   ■ ■ ■ context/     # ThemeProvider, DAW providers (SINGULAR)
■     ■   ■ ■ ■ hooks/       # Custom React hooks
■     ■   ■ ■ ■ stores/      # Zustand stores
■     ■   ■ ■ ■ styles/
■     ■     ■ ■ ■ theme.css   # CSS variable definitions (§4.1)
■     ■     ■ ■ ■ config/
■     ■ ■ ■ tailwind.config.ts # ONLY canonical Tailwind config
■     ■ ■ ■ vite.config.ts
■     ■ ■ ■ index.html
■ ■ ■ server/
■   ■ ■ ■ db/
■     ■ ■ ■ schema.ts        # Drizzle schema (single source)
■     ■ ■ ■ migrations/      # drizzle-kit generated only
■     ■ ■ ■ routers/
■     ■   ■ ■ ■ subscription.ts # Stripe + tier logic
■     ■   ■ ■ ■ auth.ts
■     ■ ■ ■ services/
■     ■   ■ ■ ■ mock-billing.ts # BILLING_MODE=mock layer
■     ■ ■ ■ routes/
■     ■ ■ ■ trpc.ts
■ ■ ■ shared/                # Universal types, schema, adapters
■   ■ ■ ■ package.json        # MUST NOT be a copy of server/package.json
■ ■ ■ packages/
■   ■ ■ ■ llpte-core/
■   ■ ■ ■ llpte-signal/       # Float32Array – see §2 esbuild pin
■   ■ ■ ■ llpte-ai-mix/
■   ■ ■ ■ llpte-transition/
■   ■ ■ ■ llpte-output/
■   ■ ■ ■ llpte-types/
■ ■ ■ tests/                 # Vitest – ≥42 cases
■ ■ ■ tools/                 # Patch, audit, automation scripts
■   ■ ■ ■ r3-audit-v5.ts
■ ■ ■ SECURITY.md            # CVE/Dependabot deferred-finding log (§7.12)
■ ■ ■ CLAUDE.md
■ ■ ■ CLAUDE.local.md       # Gitignored – never commit
■ ■ ■ WIRE.txt
■ ■ ■ .nvmrc                 # Contains: 22
```

3.2 Canonical Pipeline (LLPTE — Locked)

Node order must never change (locked in PRD + Charter). Each node exposes hooks for live visual intelligence layer.

```
inputRouter → spectralAnalyzer → aiMixEngine → transitionGraph → outputBus
```

■ 4. UI & Theming Contract

4.1 Style Union (Enforced)

- Base: Black (#000), soft white (#eaeaea)
- Accent: Neon lime (#bfff00), soft neon (#dfff66), border glow
- No random greens: Only neon palette allowed
- Theme Switcher: Only two themes: dark (default), light
- UI colors must reflect canonical tokens (bg-background, border-border, etc.)

4.2 Canonical Inline Style Palette (T-Object)

For DAW core pages (DAW.tsx, Instrument.tsx) and any component migrating off Tailwind theme classes, use the canonical inline palette:

```
const T = {
  bg:      '#0a0a0a',      // page background
  surface: '#0d0d0d',      // panel background
  border:  '#1c1c1c',      // primary borders
  border2: '#2a2a2a',      // secondary borders
  text:    '#e5e5e5',      // primary text
  dim:     '#555',         // secondary/muted text
  accent:  '#a3e635',      // acid green – primary accent
  accentDim: 'rgba(163,230,53,0.12)', // accent tint for hover states
  rec:     '#ef4444',      // record red
  recDim:  'rgba(239,68,68,0.15)', // record tint
  font:    '"IBM Plex Mono", "JetBrains Mono", monospace',
}
```

Palette disambiguation: The CSS variable system (§4.1, Appendix A) uses **#bfff00** as --neon-lime. The T-object uses **#a3e635** as accent. These are intentionally separate: CSS vars drive Tailwind/theme.css tokens; T-object drives DAW core inline styles. Do NOT unify them or substitute one for the other.

Palette Unification Path (non-blocking, tracked)

The two-green split is a known future maintenance surface. The unification trigger is: *completion of full Tailwind→inline migration across DAW.tsx and Instrument.tsx*. At that point, --neon-lime may be aliased to #a3e635 in theme.css and the T-object accent can be promoted to the CSS var system. Owner: @r3-maintainer. Do not attempt unification before that milestone.

4.3 Tailwind → Inline Migration Swaps

Tailwind Class	Inline Replacement
bg-card	background: '#0d0d0d'
bg-background	background: '#0a0a0a'
bg-muted	background: 'rgba(255,255,255,0.04)'
text-blue-400	color: '#a3e635'
rounded-lg	(remove — zero radius is canonical)
from-blue-600 to-blue-700	background: rgba(163,230,53,0.12), border: 1px solid rgba(163,230,53,0.4), color: #a3e635

4.4 Neon Effects

- Buttons, panels, indicators: neon-border, neon-panel, .neon-hover classes.
- Only use box-shadow and border-color for glow, never inline RGB hack.
- Animation speed: Default 220ms. No infinite blur spam.

4.5 Audio/Beat/Section/VJ Integration

UI livesyncs to: master output, active tracks, beat, bar, drop, and MIDI. Use global context: useVisualIntelligence, useAudioReactivity, useMusicClock.

4.6 Accessibility

- All live themes pass WCAG AA for contrast on both backgrounds.
- Focus rings: Neon, always visible.

■ 5. AI, Visual, and Realtime Intelligence

Layer	Function	Requirement
Audio Analyzer	Level, waveform, FFT bands	60fps, smoothed
Beat Clock	Beat/bar/phrase counters	BPM lock, 4/8/16 bar
Drop Detector	Energy spike → UI explosion	Smoothing, 20ms delay
Section Detection	AI classifies verse/build/drop	Heuristics + ML
Visual Intelligence Layer	Aggregates signals, feeds VJ/reactive UI	Central, not per-comp
MIDI Handler	Per-user, per-session, triggers UI	Web MIDI, low-latency
Node-Based VJ Graph	Shader logic built visually	ReactFlow + WebGL
Collaborative Editing	CRDT graph (Yjs) w/ undo	Multi-user, no merge

- VJ visuals (WebGL shader canvas) driven by VIL data, not React state.
- AI copilots allowed, but must patch via diff/patch system, not raw writes.

■ 6. Monetization & User Flow

Tier	Feature Locks	Enforcement
explorer	Limited tracks, basic AI, branding	Stripe/canonical only
creator	Full tracks/effects, MIDI, DAW/VJ collab	Stripe validated
pro_artist	All features, multiplayer, live visuals, export	Stripe, audit required

- On login: always redirect /instrument, never /daw.
- Stripe is the only payment gateway (no alt vendors).
- No "Pro" or "Studio" strings — only **creator** or **pro_artist**.

7. Dev / Test / Deployment Protocols

7.1 Zero Drift Rule

- pnpm tsc --noEmit must return zero errors after any patch.
- Always run pnpm tsc --noEmit immediately after git pull to catch JSX/type errors introduced from other machines.
- Patch scripts must perform read-first (WIRE.txt protocol).

7.2 CI Enforcement — Automated Gates

Rules stated in §7.1 are enforced automatically. A merge or deploy that skips these gates is a protocol violation, not a judgment call.

Gate	Command / Check	Blocks	On failure
TypeScript strict	pnpm tsc --noEmit	Merge to main	Fix type errors — no suppressions
Lint	pnpm eslint client/src --max-warnings 0	Merge to main	Fix or explicitly exempt with comment
Unit tests	pnpm vitest run (≥42 cases)	Merge to main	Fix failing tests — never skip
Theme token audit	grep -rn bg-black text-white border-green client/src/	Deploy	Replace with canonical tokens (§4.3)
Frozen lockfile	pnpm install --frozen-lockfile (CI only)	Deploy	Commit updated lockfile from Kali only
esbuild pin	ls node_modules/.pnpm/ grep esbuild → Deploy 0.25.12	Deploy	Pin override in pnpm.overrides
Security triage	All open Dependabot alerts triaged per §7.2.2	Release	Complete triage; no silent closes

Recommended pipeline order (GitHub Actions or equivalent):

```
1. pnpm install --frozen-lockfile 2. pnpm tsc --noEmit 3. pnpm eslint client/src --max-warnings 0 4. pnpm vitest run 5. grep -rn "bg-black|text-white|#[0-9a-fA-F]{3,6}" client/src/ → fail if matches 6. ls node_modules/.pnpm/ | grep esbuild → assert 0.25.12 # Steps 1-6 gate merge. Step 7 gates deploy only: 7. pnpm drizzle-kit migrate (Railway DATABASE_URL injected by CI secret)
```

DATABASE_URL is injected by the CI secret store — never stored in the repo or .env files. If the CI secret is missing, the migration step fails loudly rather than connecting to a wrong DB.

7.3 pnpm Install — Frozen Lockfile Required

```
pnpm install --frozen-lockfile # Verify esbuild after install on any non-Kali machine: ls node_modules/.pnpm/ | grep esbuild # expect: esbuild@0.25.12
```

Never run bare pnpm install on secondary machines — it may silently resolve wrong versions (e.g. esbuild@0.27.7 instead of pinned 0.25.12).

7.4 Theme Preflight

Before every deploy, run grep across all UI for non-token colors:

```
grep -rn "bg-black\|text-white\|border-green\|#[0-9a-fA-F]{3,6}" client/src/
```

7.5 Config Lock

- Only one live tailwind.config.ts in client/ root.
- No dev on Termux/Penguin except isolated UI run.
- .env DB_URL must always be manually verified (Railway only).

7.6 Railway Database — Migration Protocol

drizzle-kit migrate prints a spinner but gives no explicit success message. Always verify immediately after every migration.

```
# Always explicitly override DATABASE_URL – never trust .env
DATABASE_URL="postgresql://postgres:PASSWORD@ballast.proxy.rlwy.net:PORT/railway" \ pnpm
drizzle-kit migrate # Verify immediately after: DATABASE_URL="..." node -e " const
{Pool}=require('pg'); const pool=new Pool(...); pool.query("SELECT column_name FROM
information_schema.columns WHERE table_name='users'") .then(r=>{console.log(r.rows.length+'
cols ■'); pool.end();}) "
```

7.7 Admin Login Verification Pattern

```
# Step 1 – Confirm admin user exists in DB node -e "require('dotenv/config'); ... SELECT
id,email,isAdmin,tier FROM users WHERE isAdmin=true" # Step 2 – Confirm ADMIN_EMAIL env var
grep "ADMIN_EMAIL" ~/Stable/.env # Step 3 – Test the auth endpoint curl -s -X POST
http://localhost:3000/api/auth/login \ -H "Content-Type: application/json" \ -d
'{"email":"ADMIN","password":"PASS"}'
```

7.8 Python Patch Script Delivery

On Termux/Android, heredoc syntax fails when pasted into nano. Always deliver Python patches via stdin directly:

```
python3 - << 'EOF' # pure python only – no cat, no PYEOF, no shell wrapper import shutil ...
EOF
```

7.9 GPG Secrets Archive

For Railway operations, opening railway.app in a browser and copying the DB URL is almost always faster than decrypting the archive. Use that first.

```
# Encrypt cd ~/Stable && ./r3zip-secrets.sh # Decrypt ./r3zip-secrets.sh --decrypt
```

7.10 GitHub Authentication

GitHub deprecated password authentication. HTTPS pushes require a Personal Access Token (PAT).

```
# Option A – embed in remote URL git remote set-url origin
https://USERNAME:PAT@github.com/Berryboy9/... # Option B – credential store (prompted once,
then cached) git config --global credential.helper store
```

7.11 Ctrl+C / Interrupted Operation Recovery

```
# git push interrupted git log --oneline -3 # confirm local commit exists git push # re-run –
idempotent, safe # pnpm install interrupted rm -rf node_modules && pnpm install
--frozen-lockfile # tar extraction interrupted (Termux) ls -la ~/r3v4_extracted/ # If partial:
rm -rf ~/r3v4_extracted && re-extract from archive
```

7.12 Standing Rules

- **CRDT/Realtime:** All multiplayer/VJ graph state must use Yjs-CRDT. Never plain Zustand or raw WebSocket for shared state.

- **AI graph patches:** All AI code must use type: "ai.generate" | "ai.modify" meta nodes. Never raw mutation.
- **CLAUDE.local.md:** After every session, update it — move completed items to a dated note, log what happened, record the Railway host (never the password). It is gitignored by design and must never be committed.

7.13 Security Triage — Mythos-Grade Protocol ■

Source: All threat-model claims trace to *Assessing Claude Mythos Preview's cybersecurity capabilities*, red.anthropic.com, April 7 2026 (edited April 9). When this section and that source disagree, the source wins. This section sits before the WIRE edit step — triage first, patch second.

Fast-Path: Dev-Build-Isolated Triage (80% of Dependabot alerts)

Most Dependabot alerts on this stack are transitive dev-build dependencies with no runtime surface. Before running the full five-lesson workflow, apply this three-question fast-path. If all three answers are NO, use the batch workflow and skip to SECURITY.md logging. If any answer is YES, exit the fast-path and run the full workflow from Lesson 1.

#	Question	If YES →
Q1	Does this dep (or anything that depends on it in the build graph) ever process attacker influence? — PR build context dep README	Follow on workflow. Surface — PR build context dep README
Q2	Is there any path from this dep into the shipped bundle — a build plugin, postinstall script, or build step? — Full workflow Surface step Build step hook	Full workflow. Surface step — PR build context dep README
Q3	Does this dep have access to credentials that overlap with production — .env.development, .env.production, or secrets? — Full workflow Surface step Build step hook	Full workflow. Surface step — PR build context dep README

If all three are NO: document in SECURITY.md as a batch entry (one entry per component, not per CVE), pin the version, set a quarterly review date. Do not open individual tickets per alert. **This is the correct outcome for the majority of Dependabot noise.**

Threat Model Reframe (read before any triage)

Shift 1 — Assume the adversary has a Mythos-class model. The Mythos writeup establishes that the model identifies and exploits zero-day vulnerabilities in every major OS and browser when directed to, and that non-experts can drive it overnight. Published exploit costs: ~\$1,000–\$2,000 per N-day exploit produced; ~\$20,000 for an OpenBSD-scale finding run. Attacker economics have shifted accordingly.

Under this assumption, re-price every "an attacker would need to..." claim. Steps that are chained but individually probable — a model grinds through them in parallel. Reverse-engineering a minified bundle, fuzzing an undocumented API, correlating two leaked facts — all cheap now.

Shift 2 — When a CVE is public, the clock is already running. Mythos produced working N-day exploits fully autonomously starting from just a CVE identifier and a git commit hash. A published CVE is not a queue item; it is a countdown. N-day findings cannot be deferred on the same terms as silent-but-known issues.

Lesson 1 — Severity Grading Is a Calibrated Skill, Not a Lookup

Expert contractors agreed with Mythos severity assessments in 89% of cases exactly, and within one level in 98%. That's the calibration bar.

- Grade the finding yourself on CVSS-style axes (AV, AC, PR, UI, C/I/A) **before** reading the advisory severity. This prevents anchoring.
- Compare after. Exact match → proceed. Within one level → proceed, note delta. More than one level apart → **stop** and resolve explicitly.
- Uncertainty rule: when genuinely between two levels, round up.
- Do **not** round toward the advisory. The advisory does not know your codebase.

Lesson 2 — Your Dependabot Queue Is a Floor, Not a Ceiling

The Mythos writeup frames its published findings as "a lower bound on the vulnerabilities and exploits that will be identified over the next few months." The known queue understates real risk. For each component in a finding, ask: what class of bug is typical here, and have we ever audited that surface?

Bug classes Mythos has demonstrated competence at finding: path traversal in static file servers, prototype pollution, complete auth bypasses, SQL injection via raw template strings, row-level auth gaps, nonce reuse, weak RNG, ReDoS in user-supplied regex. If a surface has never been audited, add a SECURITY.md follow-up item even if Dependabot is quiet today.

Lesson 3 — Friction Is Not Security; Barriers Are

Mitigations whose security value comes from friction rather than hard barriers may become considerably weaker against model-assisted adversaries. Test: if the attacker runs this attempt a million times in parallel with model assistance, does the mitigation still hold?

Class	Examples	Verdict under Mythos-class attacker
Hard barrier	Cryptographic verification; capability/permission model; typed schema; isolation	Retain as is. Treat trust boundary; process isolation; W^X; HMA
Friction	Obscurity ("undocumented endpoint"); long-but-guessable tokens with no expiry; long install chains where each step is ind	Degrade to mitigated, unless step

If the only mitigation present is friction, the finding is not resolved even if someone has written "mitigated" next to it. Friction-only deferral for a runtime finding requires explicit written risk acceptance (Lesson 5).

Lesson 4 — Surface Matters; Dev-Only ≠ Safe, but Blast Radius Differs

Dev/build-only vulnerabilities are real risk, but the attacker target is your CI environment or developer machines, not internet users. Ask in order:

- Does the dev-only tool ever process attacker-influenced input? (PR markdown, dep README, public-registry schema, webhook during CI.) → If yes, treat closer to runtime.
- Is there a supply-chain path from the dev-only component into shipped artifacts? (Build plugin, postinstall script, codegen step, bundler transform.) → If yes, treat as runtime.
- Does the dev-only tool have access to credentials that overlap with production? (Dev DB credentials, API keys with prod scope in .env.development, CI secrets used for both build and deploy.) → If yes, treat as runtime.
- Otherwise: document, pin the version, plan the upgrade. Do not silently dismiss.

Lesson 5 — Defer Is Valid, but N-Day Rewrites the Terms

Every deferred finding needs three fields — owner, trigger, interim control — or it's not deferred, it's unmanaged.

- **Owner** — a named person (@handle), not a team, not a label.
- **Revisit trigger** — a date or concrete event ("before first external beta user"; "before opening registration"). "Post-MVP" alone fails this test.
- **Interim control** — a barrier-class mitigation, or explicit written risk acceptance with reasoning.

For N-day findings (advisory is public with a patched-version reference):

- Trigger must be a **date**, not an event. The exploit-development clock does not wait for your MVP.
- Trigger date ≤ **30 days** from advisory publication for High/Critical.
- Trigger date ≤ **90 days** from advisory publication for Medium.
- Friction-only interim is **not acceptable** for runtime N-day findings rated Medium or above. Either a barrier-class interim exists, or the finding is blocking — not deferred.

Decision Table

Surface	Severity	Status	Action
Runtime	Critical/High	N-day (public CVE)	Block release. Fix now. SLA ≤ 30 days.
Runtime	Critical/High	Not public	Block release. Fix now.
Runtime	Critical/High	Any, friction-only fix exists	Block release. Do not ship; escalate to architect.
Runtime	Medium	PR still open	Block merge. Fix in the same change.
Runtime	Medium	Already merged to main	Fix now as a dedicated change.
Runtime	Medium	N-day, non-trivial fix	Defer only with barrier-class interim and date ≤ 90 days from advisory.
Runtime	Medium	Not public, non-trivial fix	Defer with barrier-class interim control only.
Runtime	Low	Clean fix	Fix now. (Cheap.)
Dev-build, supply-chain path	Any	Any	Treat as runtime — use runtime rows above.
Dev-build, credential pivot to prod	Any	Any	Treat as runtime — use runtime rows above.
Dev-build, processes attacked	Any	Any	Fix or pin + interim control + SECURITY.md entry.
Dev-build, isolated (no supply-chain, no creds)	Any	Any attacker input	Document in SECURITY.md, pin version, review quarterly.
Any	Any	Deferred	Owner + trigger (date for N-day) + interim control in SECURITY.md, or it's u

Per-Finding Note Format

Finding: <CVE/GHSA/advisory ID> – <component>@<version>
 Advisory status: <public / under embargo / internal finding>
 Advisory published: <YYYY-MM-DD or N/A>
 Surface: <runtime / dev-build-supply-chain / dev-build-credential-pivot / dev-build-isolated>
 Input path: <attacker-controlled source> → <named function/module> → <vulnerable sink>
 Severity (ours): <Critical/High/Medium/Low> – <one-line reasoning under Mythos-class attacker>
 Severity (advisory): <level> • Delta: <same / ±1 noted / >1 STOP>
 Mitigation class: <barrier / friction / none>
 Mythos-class re-price: <which "attacker would need X" claims no longer hold>
 Decision: <block merge / block release / fix now / defer>
 If deferred – owner / trigger (date required for N-day) / interim control class: <...>

SECURITY.md Deferred-Finding Template

```

### <CVE or GHSA ID> – <component>@<version>
- **Status:** Deferred
- **Advisory status:** <public / under embargo / internal finding>
- **Advisory published:** <YYYY-MM-DD or N/A>
- **Surface:** <runtime | dev-build-supply-chain | dev-build-credential-pivot | dev-build-isolated>
- **Our severity assessment:** <Critical/High/Medium/Low> – <one-line reasoning>
- **Advisory severity:** <level> – <delta noted>
- **Mythos-class re-price:** <what "attacker would need X" claims no longer hold>
- **Why deferred:** <concrete reason, not "time">
- **Interim control:** <barrier-class control named | friction-only, accepted risk because...>
- **Revisit trigger:** <ISO date; for N-day findings a date is required, not an event>
- **Owner:** <@handle>
- **Upgrade path:** <e.g., "vite 5 → 6 migration, blocked on X">
  
```

Batch Workflow (for queues of many findings)

- **Dedup first.** The same CVE frequently appears via multiple transitive paths. Collapse to one finding per (CVE, vulnerable package version) pair, listing all dependency paths. Triage once.
- **Group by surface:** runtime / dev-build-supply-chain / dev-build-credential-pivot / dev-build-isolated.
- **Grade by sampling:** fully grade three findings per group as calibration anchors, then grade the rest relative to those anchors.
- Dev-build-isolated findings may be captured as a single SECURITY.md batch entry per component. Runtime findings always get individual entries.
- If one component produces many findings at once, investigate whether it's a single bad release or a structural quality problem — the two have different remediations.

Anti-Patterns (flag loudly)

- "It's a transitive dev dep, ignore it." — Valid only after Lesson 4 confirms no supply-chain path, no attacker-influenced input, and no credential pivot to production.
- "We'll fix it post-MVP." — Valid only with a concrete trigger and named owner; N-day requires a date $\leq 30/90$ days.
- "The attacker would need to X first." — If X is achievable at scale by a model-assisted adversary, X is friction, not a barrier.
- "The fix is out but we haven't tested it yet." — Not a deferral reason. Every hour you delay, weaponized-exploit probability rises.
- "Dependabot fires too often, we batch weekly." — Batching runtime-surface findings is not acceptable. N-day findings cannot be batched with silent-but-known ones.
- Accepting the advisory severity unchanged without independent re-grading. Advisories are written for generic deployments; yours isn't generic.
- Silently closing a Dependabot alert. Always leave Pass-1/Pass-2 reasoning as a comment, even if the conclusion is "not applicable."
- "We're not a big enough target." — Mythos-class capability drops attacker cost to ~\$1k–\$2k; obscurity-of-target is not a control.
- "Dependabot didn't flag anything this week." — Lesson 2 exists precisely because unknowns are real.
- Grading without the Mythos-class re-price step. Skipping it produces 2015-era severity numbers.

WIRE Integration

This section sits **before** the WIRE edit step. It produces two artifacts — the per-finding note and the SECURITY.md diff — and then hands off to WIRE to actually apply any code or config changes. Triage and remediation are separate phases; don't collapse them, and don't let "just fix it" skip the note.

■ ■ 8. Hygiene & Canonical Violations

8.1 Style & Type Guards

NO:

- bg-black, text-white, border-green-500 (except in inline DAW core palette by explicit design)
- Direct color hex in className props outside styles/theme.css or DAW core
- Committing console.log — use structured logging everywhere
- any types — must use unknown with guard, unless CLAUDE-exempt file
- Phantom directories — never new UI in client/client, client/src/context(s), etc.
- Multiple tailwind configs — only client/tailwind.config.ts is canonical

DO:

- ESLint + TS strict enforced before any merge
- pnpm tsc --noEmit after every patch

8.2 Double Transport Bar — Prevention Pattern

Components that own an internal transport bar must accept hideTransport?: boolean. Pass hideTransport={true} from any route wrapper that lives inside a nav-aware shell.

```
interface Props { hideTransport?: boolean; } const Component = ({ hideTransport = false }: Props) => ( <{!hideTransport && (<{ /* internal transport */})}{ /* rest */ } ); // In App.tsx route:
```

8.3 JSX Fragment Pitfall

When wrapping JSX with {condition && (...)}, if the first child is a comment, Babel/esbuild throws Unexpected token. Always wrap with a fragment:

```
// WRONG {!hideTransport && ( { /* comment */ } ... )} // CORRECT {!hideTransport && (< { /* comment */ } ... )}
```

8.4 Unterminated JSX — StatusBar Pattern

A stray with no matching opening <> produces Unterminated JSX contents at build time. Diagnosis (line numbers approximate — use grep first):

```
grep -n "StatusBar\|const StatusBar" ~/Stable/client/src/pages/DAW.tsx sed -n '1840,1870p' ~/Stable/client/src/pages/DAW.tsx # line numbers as of v4.3; may drift
```

8.5 Git Large File Rules

Never commit archives, secrets, or logs. Verify .gitignore before any commit.

```
archives/*.tar.gz archives/*.gz archives/*.zip secrets/ logs/
```

Use --force-with-lease instead of --force for regular force-push situations — it aborts if the remote has commits you haven't fetched, preventing accidental overwrites.

```
git push --force-with-lease
```

8.6 PRD Version Triple-Check Process

When updating this PRD or any technical document:

- **Pass 1** — Targeted search for known wrong values: `grep -n "OLD_VALUE|stale_string|wrong_count" file.md`
- **Pass 2** — Cross-reference all numerical claims: count items, verify math, check version numbers against pinned stack.
- **Pass 3** — Context sweep: search every instance of key terms across ALL sections. Changelog, glossary, and prose paragraphs hold stale values longest.

■ 9. Roadmap: Next-Level Features

Owner column requires a named person (@handle). Trigger column requires either a hard date or a concrete, calendar-anchored event. "Post-MVP" alone fails validation.

Item	Phase	Target / Trigger	Owner	Notes
Neon/Acid theme full migration	Immediate	2026-05-15	@r3	~1d scope; grep audit included
Theme/dark-mode indicator audit	Immediate	2026-05-15	@r3	Multi-pass; run after theme migration
Audio reactivity engine + beat/section detection	Immediate	2026-05-22	@r3	Hooks: useAudioReactivity, useMusicClock
Node-based VJ visual composer (single-user)	Staged	2026-06-01	@r3	ReactFlow + WebGL; single-user only at this stage
Multiplayer collaborative VJ (≥pro)	Staged	2026-07-01	@r3	Yjs-CRDT only; no plain Zustand
AI co-creator nodes (codegen/LLM-backed)	Staged	2026-07-01	@r3	type: ai.generate ai.modify meta nodes only
Live drop detection + visual cues	Staged	2026-07-15	@r3	Smoothing, 20ms delay (\$5)
Visual automation lanes for modulators	Staged	2026-07-15	@r3	—
Preset system for VJ patches/scenes	Staged	2026-08-01	@r3	—
Promo Code System	Deferred	2026-09-01	@r3	New promoCodes Drizzle table; next migration after

10. Appendix A: Canonical Color/Theme Token Map

These CSS variables are defined in client/src/styles/theme.css and drive the Tailwind/theme.css token system. Do not redefine them inline; use §4.2 T-object for DAW core inline styles only.

Variable	Value	Usage
--bg	#000000	Page base background
--fg	#eaeaea	Primary foreground text
--neon-lime	#bfff00	Primary accent (CSS-var system) — see §4.2 re: T-object delta
--neon-lime-soft	#dfff66	Soft accent
--border	#bfff00	Border accent color
--panel	#050505	Panel background
--glow-1	0 0 4px #bfff00	Level 1 glow
--glow-2	0 0 8px #bfff00, 0 0 16px #bfff00	Level 2 glow
--glow-3	0 0 12px #bfff00, 0 0 24px #bfff00, 0 0 48px #bfff00	Level 3 glow

11. Appendix B: Inline Style Palette (DAW Core Reference)

Canonical definition lives in §4.2 — the T-object is defined there and only there. Do not duplicate it here; two copies is exactly what causes palette drift. This appendix entry exists purely as a findability anchor. To update the palette, edit §4.2 only.

This PRD must be reviewed alongside CLAUDE.md, SKILLS.md, WIRE.txt, and Mythos-Skills.pdf before every feature or patch. No deviations permitted without RFC and maintainer review.